

COMPTE RENDU DE TP 4.2 : DÉTECTION D'ATTAQUES AVEC UN IDS/IPS (SURICATA SUR PFSense)

Objectif : Mise en place d'un système de détection (IDS) et de prévention d'intrusion (IPS) pour sécuriser le réseau LAN.

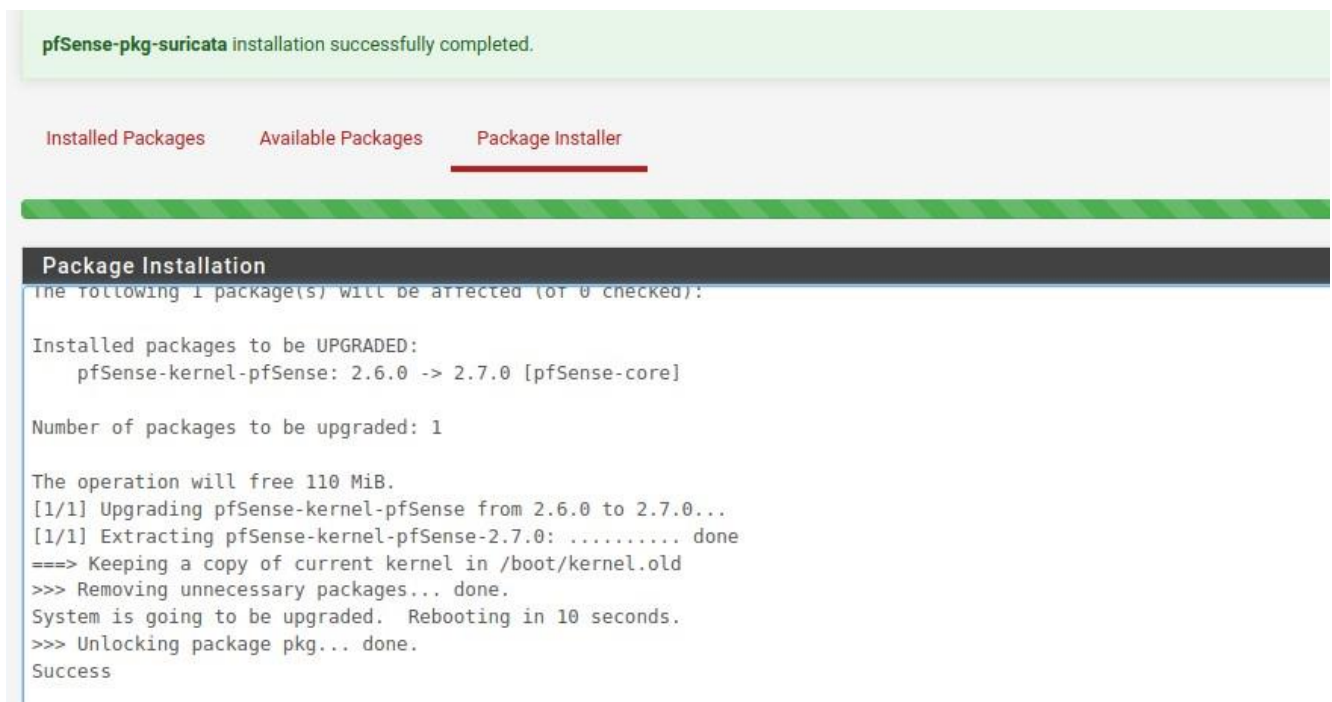
1. Introduction et Objectifs

L'objectif de ce TP est d'ajouter une couche d'intelligence à la sécurité réseau de l'infrastructure NetSecure. Alors qu'un pare-feu classique se contente de bloquer des ports, l'utilisation de **Suricata** permet d'analyser le contenu du trafic en temps réel pour identifier des signatures d'attaques spécifiques (scans, tentatives d'exploitation, etc.).

2. Mise en œuvre technique

2.1 Installation et Configuration de Suricata

L'installation a été réalisée sur l'interface pfSense via le gestionnaire de paquets.



```
pfSense-pkg-suricata installation successfully completed.

Installed Packages    Available Packages    Package Installer

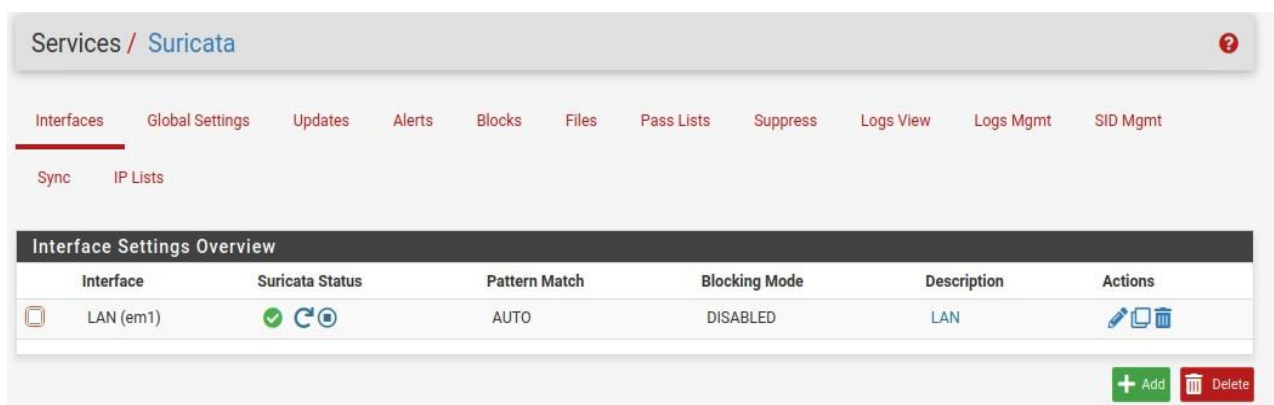
Package Installation
The following 1 package(s) will be affected (of 0 checked):

Installed packages to be UPGRADED:
  pfSense-kernel-pfSense: 2.6.0 -> 2.7.0 [pfSense-core]

Number of packages to be upgraded: 1

The operation will free 110 MiB.
[1/1] Upgrading pfSense-kernel-pfSense from 2.6.0 to 2.7.0...
[1/1] Extracting pfSense-kernel-pfSense-2.7.0: ..... done
====> Keeping a copy of current kernel in /boot/kernel.old
>>> Removing unnecessary packages... done.
System is going to be upgraded. Rebooting in 10 seconds.
>>> Unlocking package pkg... done.
Success
```

- **Interface surveillée** : Le LAN a été choisi car c'est là que se situent les machines sensibles (Ubuntu et Windows) à protéger après une première compromission.



- **Activation des signatures** : Les règles "ET Open Rules" ont été activées et mises à jour pour permettre à Suricata de reconnaître les menaces connues.



2.2 Passage en mode IDS (Détection)

Dans un premier temps, Suricata a été configuré pour observer sans bloquer.

- **Test effectué** : Un scan Nmap furtif (*sudo nmap -sS 192.168.1.10*) a été lancé depuis Kali vers la machine Ubuntu.

D'après l'image ci-dessous, nous avons effectué 02 scans afin d'obtenir 02 alertes suricata.

```
ngulfatse@ngulfatse:~$ sudo nmap -sS 192.168.1.10
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-28 09:51 WAT
Stats: 0:00:00 elapsed; 0 hosts completed (1 up), 1 undumping SYN Stealth Scan
SYN Stealth Scan Timing: About 37.00% done; ETC: 09:51 (0:00:00 remaining)
Nmap scan report for 192.168.1.10
Host is up (0.0011s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 00:0C:29:FA:1C:6A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.61 seconds
ngulfatse@ngulfatse:~$

ngulfatse@ngulfatse:~$ sudo nmap -sS 192.168.1.10
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-04-28 09:51 WAT
Nmap scan report for 192.168.1.10
Host is up (0.00094s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 closed tcp ports (reset)
MAC Address: 00:0C:29:FA:1C:6A (VMware)

Nmap done: 1 IP address (1 host up) scanned in 0.60 seconds
ngulfatse@ngulfatse:~$
```

- **Observation** : Dans l'onglet **Services** -> **Suricata** -> **Alerts**, des alertes ont été générées, prouvant que l'attaque a été détectée même si elle n'a pas été bloquée.

Services / Suricata / Alerts

Interfaces Global Settings Updates Alerts Blocks Files Pass Lists Suppress Logs View Logs Mgmt SID Mgmt

Sync IP Lists

Alert Log View Settings

Instance to View (LAN) LAN
Choose which instance alerts you want to inspect.

Save or Remove Logs Download Clear
All alert log files for selected interface will be downloaded Clear the currently active Alerts log file

Save Settings Save Refresh 250
Save auto-refresh and view settings Default is ON Number of alerts to display. Default is 250

Alert Log View Filter

Last 250 Alert Entries. (Most recent entries are listed first)

Date	Action	Pri	Proto	Class	Src	SPort	Dst	DPort	GID/SID	Description
04/28/2026 08:52:24	⚠	3	UDP	Generic Protocol Command Decode	192.168.1.10	47123	142.250.188.14	443	1:2231000	SURICATA QUIC failed decrypt
04/28/2026 08:52:24	⚠	3	UDP	Generic Protocol Command Decode	192.168.1.10	47123	142.250.188.14	443	1:2231000	SURICATA QUIC failed decrypt

Nous avons aussi lancer un test d'attaque via Kali Linux par la commande **msfconsole** afin de lancer une tentative d'exploitation avec la commande :

use

auxiliary/scanner/smb/smb_version

RHOSTS 192.168.1.10 run

```
Metasploit Documentation: https://docs.metasploit.com/

msf6 > use auxiliary/scanner/smb/smb_version
msf6 auxiliary(scanner/smb/smb_version) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf6 auxiliary(scanner/smb/smb_version) > run

[*] 192.168.1.10: - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smb/smb_version) > 
```

La figure ci-dessous presente les détections de suricata des différentes tentatives d'exploitation effectuées

Interfaces	Global Settings	Updates	Alerts	Blocks	Files	Pass Lists	Suppress	Logs View	Logs Mgmt	SID Mgmt
Sync	IP Lists									
Alert Log View Settings										
Instance to View (LAN) LAN										
Choose which instance alerts you want to inspect.										
Save or Remove Logs										
Download										
All alert log files for selected interface will be downloaded										
Clear										
Clear the currently active Alerts log file										
Save Settings										
Save										
Save auto-refresh and view settings										
Refresh										
Default is ON										
250										
Number of alerts to display. Default is 250										
Alert Log View Filter										
Last 250 Alert Entries. (Most recent entries are listed first)										
Date	Action	Pri	Proto	Class	Src	SPort	Dest	DPort	GID:SID	Description
04/28/2026 10:19:19	⚠	3	TCP	Generic Protocol Command Decode	192.168.1.10	34664	34.107.221.82	80	1:2210046	SURICATA STREAM SHUTDOWN RST invalid ack
04/28/2026 10:19:19	⚠	3	TCP	Generic Protocol Command Decode	192.168.1.10	34664	34.107.221.82	80	1:2210045	SURICATA STREAM Packet with invalid ack
04/28/2026 10:19:19	⚠	3	TCP	Generic Protocol Command Decode	192.168.1.10	34674	34.107.221.82	80	1:2210046	SURICATA STREAM SHUTDOWN RST invalid ack
04/28/2026 10:19:19	⚠	3	TCP	Generic Protocol Command Decode	192.168.1.10	34674	34.107.221.82	80	1:2210045	SURICATA STREAM Packet with invalid ack

Ensuite, nous allons passer en mode blocage (IPS) et lancer une tentative Nmap. Puis nous allons aller dans suricata vérifier les alertes.

Le Block Offenders est activé. Il permet de bloqué u, utilisateur suspect.

Alert and Block Settings	
Block Offenders	☒ Checking this option will automatically block hosts that generate a Suricata alert.
IPS Mode	Legacy Mode Select blocking mode operation. Legacy Mode inspects copies of packets while Inline Mode inserts the Suricata inspection engine into the network stack between the NIC and the OS. Default is Legacy Mode. Legacy Mode uses the PCAP engine to generate copies of packets for inspection as they traverse the interface. Some "leakage" of packets will occur before Suricata can determine if the traffic matches a rule and should be blocked. Inline mode instead intercepts and inspects packets before they are handed off to the host network stack for further processing. Packets matching DROP rules are simply discarded (dropped) and not passed to the host network stack. No leakage of packets occurs with Inline Mode. WARNING: Inline Mode only works with NIC drivers which properly support Netmap! Supported drivers include: brxt, cc, cxgbe, cxl, em, ena, ice, igb, igc, ix, ixgbe, txl, lem, re, vmx, vtnet. If problems are experienced with Inline Mode, switch to Legacy Mode instead.
Kill States	☒ Checking this option will kill firewall states for the blocked IP. Default is Checked.
Which IP to Block	BOTH Select which IP extracted from the packet you wish to block. Choosing BOTH is suggested, and it is the default value.
Block On DROP Only	☐ Checking this option will insert blocks only when rule signatures having the DROP action are triggered. When not checked, any rule action (ALERT or DROP) will generate a block of the offending host. Default is Not Checked.
IP Pass List	default Choose the Pass List you want this interface to use. Addresses in a Pass List are never blocked. Select "none" to prevent use of a Pass List. The default Pass List adds Gateways, DNS servers, locally-attached networks, the WAN IP, VPNs and VIPs. Create a Pass List with an alias to customize whitelisted IP addresses. This option will only be used when block offenders is on. Choosing "none" will disable Pass List generation. View List
Enable Passlist Debugging Log	☐ Checking this option will enable detailed Passlist operations logging to file /var/log/suricata/suricata_em144392/passlist_debug.log. Default is Not Checked.

Nous avons constaté que la tentative Nmap est très lente et bloquée. La page alerte est vide.

3. Méthode de détection de suricata

La Détection par Signatures (Le "Matching")

C'est la méthode la plus courante. Suricata possède une base de données contenant des milliers de "fiches signalétiques" appelées **signatures** ou **règles**.

- **Le principe** : Chaque règle contient des caractéristiques précises d'une attaque connue (une suite de caractères spécifique, un port inhabituel, ou une taille de paquet anormale).
- **L'action** : Suricata compare chaque paquet qui passe sur le réseau avec ces règles. Si le contenu du paquet correspond exactement à une règle (par exemple, la signature d'un scan Nmap), une alerte est déclenchée.

L'Analyse de Protocole (L'Analyse Intelligente)

Suricata ne se contente pas de lire le texte des paquets ; il comprend les "langages" du réseau (HTTP, SMB, FTP, TLS, etc.).

- **Le principe** : Il vérifie si le trafic respecte les règles normales du protocole.

- **Exemple** : Si quelqu'un essaie d'envoyer des commandes de terminal à travers une connexion qui devrait être uniquement du trafic web (HTTP), Suricata détecte cette anomalie car elle ne respecte pas la structure normale du langage HTTP.

4. Analyse et Compréhension

4.1 Différence entre IDS et IPS

- **IDS (Intrusion Detection System)** : Agit comme une caméra de surveillance. Il voit l'attaque, génère une alerte, mais ne l'arrête pas.
- **IPS (Intrusion Prevention System)** : Agit comme un agent de sécurité. Il détecte l'attaque et ferme immédiatement l'accès pour protéger la cible.

4.2 L'importance des signatures

Suricata utilise une base de données de milliers de signatures. Sans ces règles mises à jour, l'outil serait incapable de distinguer un trafic légitime (comme une mise à jour logicielle) d'une activité malveillante (comme une tentative d'exploitation Metasploit).

5. Options avancées de Suricata

Lors de l'utilisation de l'outil, plusieurs paramètres permettent d'affiner la détection :

- **Types de règles** : Filtrage par protocole (HTTP, SMB, FTP) ou par comportement.
- **Niveaux de sévérité** : Les alertes sont classées pour aider l'administrateur à prioriser les menaces critiques.
- **Gestion des suppressions** : Possibilité d'ignorer certaines alertes pour éviter les faux positifs.

6. Conclusion

Ce TP a validé un point essentiel : les attaques réalisées précédemment (Nmap, Metasploit) sont désormais détectables et blocables. L'intégration de Suricata sur pfSense transforme un pare-feu statique en une barrière dynamique capable de réagir aux comportements anormaux, ce qui est crucial dans un environnement SOC moderne.